Synthèse du rapporteur — A5 : ECDSA et nonces faibles

Cryptographie & Technologies Blockchain — Pr Gervais MENDY — ESP-UCAD / LITA — Séance S3, mercredi 11 novembre 2026, bloc 1

Présentateurs (groupe 6) : Khadimou Rassoul Mbacké MBAYE, Fatoumata BARRO, Ndeye Mingue NDIAYE · Discutants : groupe 1 · Rapporteurs (groupe 4) : Mohamed LO, Ahmadoul Khadim TOURE, Amadou Tidiane KANE

1. Sujet et question de recherche

Une signature ECDSA (Elliptic Curve Digital Signature Algorithm) n'est sûre que si le nonce k, tiré à chaque signature, reste secret, unique et uniforme. Le groupe 6 pose la question : **reste-t-il en 2026 des signatures à nonce répété sur Bitcoin et Ethereum, et à partir de quel biais un nonce devient-il exploitable ?** Son hypothèse : la RFC (Request for Comments) 6979 et les bibliothèques modernes ont rendu la réutilisation rare, mais d'anciens portefeuilles ou des implémentations maison peuvent encore en produire ; pour un biais, le nombre de signatures t multiplié par le nombre de bits connus ℓ doit être de l'ordre de 256 bits ou plus (heuristique).

2. Ce que le groupe a présenté

Message central : **le nonce est aussi sensible que la clé privée.** La signature $s = k^{-1}(h + r \cdot d)$ mélange k et la clé d ; dès que k est connu, $d = r^{-1}(s \cdot k - h) \bmod n$. Les défauts se classent en deux familles : ceux qui cassent par un **calcul exact** (nonce réutilisé, prévisible ou lié par une relation connue) et ceux qui cassent par **réseaux euclidiens** (nonce biaisé ou qui fuit, problème du nombre caché, algorithmes LLL et BKZ). Sur une blockchain, les signatures sont publiques et permanentes : l'attaquant lit le registre sans jamais toucher au portefeuille. Le modèle d'attaque est passif, analogue d'une KPA (attaque à texte en clair connu) : il ne connaît que des couples publics (message, signature).

Exemple chiffré à la main sur la courbe jouet $y^2 = x^3 + 2x + 2$ sur F_{17} (G = (5, 1), d'ordre 19) : avec d = 7 et un nonce réutilisé k = 10, on obtient r = 7, $s_1 = 11$ et $s_2 = 6$; à partir des seules valeurs publiques, $k = (h_1 - h_2)(s_1 - s_2)^{-1} = 10$ puis d = 7 sont retrouvés (nous avons contrôlé ces calculs : ils sont exacts). La démonstration reprend la même attaque en Python pur sur secp256k1 et vérifie la clé retrouvée contre la clé publique ($d \cdot G = Q$). Les cas réels cités sont la PlayStation 3 (2010) et des portefeuilles Bitcoin sur Android (2013). Les parades présentées sont la RFC 6979 (nonce déterministe), EdDSA, Schnorr (BIP 340) et les bibliothèques éprouvées, avec la règle « ne jamais écrire sa propre génération de nonce ».

3. Le projet de recherche

Le projet suit les trois jalons de la fiche : (1) état de l'art autour de Breitner et Heninger (FC 2019) et de Brengel et Rossow (RAID 2018), avec un tableau de six travaux qui précise l'apport et la limite de chacun, et un jeu de données formé des signatures ECDSA de Bitcoin et d'Ethereum extraites d'un nœud complet ; (2) une attaque par réseaux (fpylll) sur des signatures synthétiques à biais contrôlé ; (3) un article avec la courbe « bits de biais » contre « signatures nécessaires » et le nombre de r répétés trouvés sur la chaîne, en statistiques agrégées. **La limite est assumée par le groupe : seule la réutilisation de nonce est démontrée à ce stade, l'attaque par réseaux est expliquée mais pas encore exécutée.** Le

cadre éthique est net : aucun fonds déplacé, même si une clé est retrouvée, et aucune adresse ni clé publiée.

4. Discussion

Question 1 (groupe 1) — les services concernés. Le groupe affirme que tout service de paiement signant avec ECDSA au Sénégal et dans l'UEMOA (Union économique et monétaire ouest-africaine) est concerné, sans donner d'exemple. Quels services utilisés ici signent vraiment avec ECDSA, et une étude sur Bitcoin et Ethereum dit-elle quelque chose sur leur risque ?

Réponse du groupe 6 : les services de Mobile Money classiques (Orange Money, Wave) reposent sur des architectures bancaires centralisées. En revanche, les portefeuilles de cryptomonnaies utilisés au Sénégal (MetaMask, Trust Wallet, portefeuilles matériels) signent nativement avec ECDSA, et des fintechs locales intègrent des briques Web3. Si une bibliothèque ECDSA a un aléa défectueux, le risque est le même qu'ailleurs : une erreur de nonce expose les fonds de façon irrécupérable.

Point du rapporteur : la réponse est juste sur le principe, mais aucun service sénégalais précis n'est confirmé comme signant en ECDSA, et la seconde partie de la question reste sans réponse : l'étude mesure des chaînes, pas des services, et ne dit rien du risque d'un service local tant qu'on ignore la bibliothèque qu'il utilise. Rappeler que les bibliothèques modernes appliquent la RFC 6979 (diapositive 13) aurait nuancé « tout service est concerné ».

Question 2 (groupe 1) — les attaques au Sénégal. Les attaques récentes à la DGID (2025) et à la DAF (2026) sont des intrusions avec vol de données, sans signature cassée. Pourquoi chercher un nonce faible alors qu'une intrusion classique marche déjà ?

Réponse du groupe 6 : une intrusion vise un système pour voler des données ou bloquer des services ; une attaque par nonce faible vise la clé privée elle-même. Sur Bitcoin ou Ethereum, quelqu'un qui observe des signatures publiques à nonce réutilisé retrouve la clé sans pénétrer chez le propriétaire, puis signe des transactions frauduleuses à sa place.

Point du rapporteur : c'est la réponse la plus solide, cohérente avec l'exposé (« Ève lit le registre »). Elle aurait gagné à reconnaître que les deux menaces ne se concurrencent pas (données volées d'un côté, fonds volés sur la chaîne de l'autre), que l'attaque par nonce suppose qu'un défaut existe, ce qui est rare selon l'hypothèse même du groupe, et à s'appuyer sur Brengel et Rossow, qui ont mesuré des clés fuitées et des vols réels. L'expression « une seule erreur » gagnerait aussi à distinguer la réutilisation (deux signatures suffisent) du biais (plusieurs signatures).

Question 3 (groupe 1) — pétrole, gaz et mises à jour signées. Avec Sangomar et GTA, le Sénégal dépend d'installations pilotées par des automates qui reçoivent des mises à jour signées, parfois en ECDSA, sur des appareils embarqués où le hasard est le plus faible. Le sujet les concerne-t-il, et que se passerait-il si la clé de signature fuitait à cause d'un mauvais nonce ?

Réponse du groupe 6 : comme pour la PlayStation 3, ces équipements reçoivent des micrologiciels signés par ECDSA. Un nonce faible permettrait d'extraire la clé de signature,

d'injecter de faux micrologiciels malveillants et de compromettre des infrastructures nationales sensibles.

Point du rapporteur : le scénario est cohérent avec le cas PlayStation 3 présenté (nonce constant, clé de signature extraite), mais il reste hypothétique : rien n'établit que ces installations signent leurs mises à jour en ECDSA. La réponse ne dit ni à quelle condition la clé fuit (deux signatures de même r, ou assez de nonces biaisés), ni quelles protections limiteraient les dégâts (nonce déterministe, rotation et révocation de la clé, signature dans un module matériel), ni que ce cas sort du périmètre du projet, qui porte sur Bitcoin et Ethereum.

5. Bilan du rapporteur

- **Présentation :** structure claire en cinq parties, question de recherche affichée dès la première diapositive, parole répartie entre les trois membres. L'exemple chiffré sur courbe jouet se suit pas à pas et se vérifie à la main, ce qui rend l'attaque très concrète. La diapositive sur le problème du nombre caché est la plus dense : l'idée passe, pas l'algorithme, ce que les notes du groupe assument.
- **Réponses aux questions :** pertinentes sur le principe (surtout la question 2) mais restées générales sur le contexte local : aucun service sénégalais ni installation industrielle n'est confirmé comme concerné.
- **Points forts :** une question précise avec deux seuils mesurables ; un mécanisme complet (équations, exemple jouet exact, code sur secp256k1 vérifié contre la clé publique) ; un état de l'art qui donne l'apport et la limite de chaque source ; des parades standardisées ; une éthique claire et une limite honnêtement reconnue.
- **Points à renforcer :** la moitié de la question (le seuil de biais) n'a pas encore de résultat, et aucun r répété n'a été compté sur la chaîne réelle ; le seuil « t × ℓ de l'ordre de 256 bits » est une heuristique à confirmer par la courbe annoncée ; le jeu de données n'est pas encore délimité (période, nombre de signatures, signatures Schnorr de Taproot exclues) ; le lien avec le Sénégal et l'UEMOA reste à prouver par un exemple vérifié.
- **Questions ouvertes :** les biais simulés (bits de poids fort nuls) ressemblent-ils aux biais réels observés sur la chaîne ? Le parcours couvrira-t-il assez de signatures, anciennes et récentes, pour conclure à l'absence de r répétés ? Comment compter un même r retrouvé sous deux clés publiques différentes, qui ne livre pas directement la clé ? Ces deux premiers points, confiés au discutant par la fiche, ne figurent pas parmi les questions reçues.

À retenir : un nonce réutilisé livre la clé par un simple calcul, un nonce biaisé par une attaque sur réseaux ; les parades existent (RFC 6979, EdDSA, Schnorr, bibliothèque éprouvée, jamais de nonce maison). L'ampleur réelle du problème en 2026 sur Bitcoin et Ethereum reste à mesurer : c'est le projet du groupe.